

Sonik Agent UI Completion Contract

Goal: G001 — completion contract and PDF baseline **Run start:** 2026-07-20T20:03:01Z **Contract status:** Agreement baseline; implementation work is not accepted by this document alone **Primary delivery branch:** `fix/dev-workbench-embedded-context-20260720` **Primary pull request:** SonikFM/sonik-agent-ui#61

1. Decision summary

This run will deliver a deployable, evidence-backed Agent UI and embedded Dev Workbench slice. An authenticated operator must be able to maintain a session-backed conversation across reloads and navigation, submit prompts, observe correlated model/tool lifecycle telemetry, and launch the real sandbox-backed Workbench with correct host context. Completion requires working code, fresh checks, a deployed operator journey, and an auditable rollback path.

This contract deliberately separates **implemented**, **partial**, **skeleton**, and **missing** behavior. Existing code or a passing isolated test is not enough when the intended user journey is unreachable. PR 61 is open and its quality checks were green at this baseline, but CodeRabbit still carried eight actionable contract/documentation findings. Those findings and the six pressure groups below are release work, not footnotes.

2. Sources and authority

The baseline reconciles:

- the user-approved `.omx/ultragoal/brief.md` ;
- `docs/handoffs/sonik-dev-workbench-handoff-2026-07-20/` ;
- `docs/architecture/dev-workbench-runtime-ownership-2026-07-20.md` ;
- repository implementation and tests at this worktree revision;
- current GitHub state for Agent UI PR 61 and Sonik Svelte PRs 2–8.

When sources disagree, executable repository behavior and fresh verification win. Browser evidence may describe context, but it never grants authority. Server-side contracts remain authoritative for repository selection, credentials, scopes, consequential operations, and release state.

3. Completion matrix

Capability	Baseline	Completion gate for this run	Owner
Session creation and history	Partial	Authenticated session can be created, loaded, and recovered with stable identifiers.	This run

Capability	Baseline	Completion gate for this run	Owner
Conversation persistence	Partial	Messages and active session survive reload and route navigation without destructive reset.	This run
Prompt submission	Partial	Valid prompt submits once; failure is actionable; retry does not silently duplicate.	This run
Model/tool streaming	Partial	Model text and tool lifecycle reach a terminal state; no dead or prematurely ended tool call.	This run
Telemetry and correlation	Partial	Bounded, redacted events carry session/run/message/tool correlation identifiers.	This run
Real Workbench terminal	Implemented	Real Codex CLI in named <code>tmux</code> windows remains reachable in sandbox.	Existing + this run verifies
Embedded Workbench controls	Implemented, pending release proof	Layout/source/sync/pick/capture controls are visible and keyboard reachable at embedded widths.	PR 61 + this run
Host evidence and authority	Partial	UI distinguishes evidence freshness from server authority and tool readiness; forged client context adds no scope.	This run + host integration
Preview visual context	Partial	Deterministic capture promotes one revision-matched manifest/PNG pair atomically; stale results never become current.	This run
Exact active-host pixels	Skeleton/disabled	Remains unavailable until secure pairing, attestation, redaction, and live E2E pass.	Explicit follow-up
Preview health/restart	Skeleton	No release claim until health and restart are wired and exercised.	Follow-up unless required by repair
Changed files, console, failed requests	Skeleton	No release claim until runtime data populates views and reconnect/replay works.	Follow-up/operational evidence gate
Realtime egress	Skeleton	Kind/payload contract, redaction, cursor, ordering, and replay proven before “live” claim.	This run establishes contract; wiring follows
Governed commit/push/deploy	Missing as product capability	Consequential action uses scoped server capability, explicit approval, provider request ID, and audit record.	Follow-up; shell access is not completion
MCP tool surface	Deferred/missing	Not required for this slice; existing typed contracts and terminal path are reused.	User/parallel follow-up
JSON-render canvas	Implemented	Current 33-component Svelte catalog renders validated specs and preserves state/action receipts.	Existing + this run audits
Theme authority	Implemented	DaisyUI 5.5.23 with Tailwind CSS 4 remains the single product theme authority.	Existing + this run protects

Status meanings:

- **Implemented:** operative code exists; release still requires fresh evidence.

- **Partial:** useful implementation exists but the required end-to-end contract is incomplete.
- **Skeleton:** types, UI shape, fixtures, or disabled handlers exist without complete runtime behavior.
- **Missing/deferred:** no release-ready implementation is claimed.

4. Eight unresolved PR 61 findings

The following actionable CodeRabbit findings are adopted verbatim in substance as release requirements:

1. **Server-only host authority:** define the host-authority attachment as an access-controlled, expiring, revocable server-side handle; remove it from guest filesystem paths and client state.
2. **Canonical preview status:** use one shared preview-status union covering `booting`, the established canonical ready/healthy term, `failed`, and `stale`; align every UI consumer.
3. **Realtime discrimination:** replace `payload: unknown` with a discriminated kind-to-payload contract and bounded schema for every declared `WorkbenchEvent` kind.
4. **Transcript path redaction:** replace the absolute local historical transcript path with a redacted session identifier or repository-relative pointer; keep the transcript external.
5. **Restored controls truth:** update the handoff, gaps, risk, and delivery documents to describe restored embedded controls as current behavior and attach validation evidence.
6. **Sandbox credential firewall:** explicitly deny control-plane credentials—including GitHub, Cloudflare, database, host-authority, and visual-grounding secrets—to sandbox processes; use server brokers or short-lived least-privilege tokens.
7. **Complete visual attestation example:** include `schemaVersion`, `sourceContextRevision`, `routeRevision`, `requestSequence`, `source`, and screenshot metadata, or label the example lossy and link the canonical schema; derive screenshot paths from `DEV_WORKBENCH_STATE_ROOT`.
8. **Pinned installer:** pin the skills CLI invocation itself (fixed version or vendored installer), while retaining manifest digest comparison and conditional installation.

None may be closed by prose alone where an executable contract or affected consumer exists.

5. Six contract pressure groups

P1 — Server-only authority

- Browser page context is sanitized evidence only.
- The sandbox and client receive an opaque reference, never reusable signed authority.
- Wrong tenant, expiry, revocation, wrong origin, or replay must fail closed.
- Readiness reports evidence, authority, and provider/tool scope independently.

P2 — Sandbox credential firewall

- Long-lived GitHub, Cloudflare, database, host-authority, deployment, and visual-grounding secrets remain in the control plane.
- Approved operations use a server-side broker or a short-lived, least-privilege, audience-bound token.

- Secrets must not appear in `.sonik`, process listings, terminal transcripts, telemetry, screenshots, diffs, or client JavaScript.
- Suspension and deletion semantics are explicit; filesystem persistence is never presented as secure credential restoration.

P3 — Canonical preview stale state

- Preview state uses one shared vocabulary across contract, API, and UI.
- Route, source, workspace, or revision change invalidates current context immediately.
- A late result cannot promote over a newer request sequence.
- Failed capture leaves the prior valid artifact explicitly current or explicitly invalidated; it never creates a mixed manifest/PNG pair.

P4 — Visual attestation fixture completeness

- Every attestation carries schema, source/route revisions, request sequence, source identity, provider, workspace, dimensions, hash, capture time, and declared redactions.
- Screenshot location is symbolic under `DEV_WORKBENCH_STATE_ROOT`, not a machine-specific absolute path.
- Wrong origin/tab/revision/nonce, missing redaction, oversized payload, background tab, or hash mismatch rejects promotion.
- Cross-origin frames and closed shadow roots remain honestly unpickable.

P5 — Realtime kind/payload equality

- Each event kind maps to exactly one bounded payload schema.
- Consumers narrow on `kind`; unknown or mismatched payloads are rejected or quarantined, never guessed.
- Correlation identifiers, redaction, ordering, resumable cursor, reconnect, duplicate, and out-of-order cases are tested.
- Normalized events stay separate from raw PTY bytes and provider-specific wire shapes.

P6 — Release-document gate

- Capability claims match current code and fresh journey evidence.
- Theme and component authority, JSON-render reality, external PR status, ownership, exclusions, deploy and rollback gates are explicit.
- Markdown, self-contained HTML, and valid PDF are generated before implementation proceeds.
- A later retrospective records outcomes separately; this agreement baseline is not rewritten into a success claim.

6. Theme and component boundary

The established Agent UI surface uses **DaisyUI 5.5.23 on Tailwind CSS 4**. The lockfile currently resolves Tailwind 4.2.x across workspace importers; the product contract is Tailwind 4, not a second design system. DaisyUI semantic tokens and existing Sonik/Amplify theme rules remain authoritative. This run will not introduce parallel shadcn styling, raw one-off palettes, or a replacement component library.

`shadcn-svelte` references describe adapted component behavior and JSON-render composition, not permission to mix theme systems. Accessibility basics—keyboard access, focus restoration, status announcements, contrast, target size, and reduced motion—are release requirements and are not optional polish.

7. JSON-render architecture

JSON-render is a real current implementation, not a proposal. The repository builds workspace packages for `@json-render/core`, `@json-render/svelte`, devtools, and Svelte devtools. The standalone app validates flat specs, renders through the Svelte registry, supports state updates and action receipts, stores artifacts, and exposes devtools/telemetry seams.

The current human/agent-readable registry contains **33 components**:

`Stack`, `Grid`, `Card`, `Separator`, `Tabs`, `TabContent`, `Heading`, `Text`, `Badge`, `Alert`, `Metric`, `Table`, `BarChart`, `LineChart`, `PieChart`, `Progress`, `Skeleton`, `Callout`, `Accordion`, `Timeline`, `Link`, `TextInput`, `EditableField`, `TextareaField`, `SelectInput`, `RadioGroup`, `ChoiceCards`, `QuestionCard`, `ManifestPreview`, `MissingFieldsList`, `ConfidenceTable`, `ActionRail`, and `Button`.

Architecture rules:

1. `@json-render/core` owns spec validation, stream safety, and state primitives.
2. The Svelte registry is the only renderer mapping for this product surface.
3. Specs are execution-inert; effectful actions route through allowlisted commands, policy, approval, and receipts.
4. JSONL/YAML/directive inputs are adapters into the same validated spec, not alternate runtime authorities.
5. Devtools observe bounded spec/event state and do not receive secrets or raw chain-of-thought.
6. Codegen, Ink, MCP, image, React Email, React PDF, and Three Fiber remain secondary inventory unless separately accepted.

8. Sonik Svelte PRs 2–8

All seven PRs were **open and unintegrated** at this baseline. “Mergeable” on GitHub is not the same as accepted or released.

PR	Scope	Baseline risk / gate
#2	Remaining 18 AI Elements	CI <code>unit + build + size</code> failing; do not claim available in Agent UI until merged, versioned, adopted, and verified.
#3	Vendored svelte-streamdown and streamed markdown demo	CI failing; provenance, bundle, stream safety, and design-system fit must pass before adoption.
#4	Chat and EmojiPicker donor components	CI failing; donor drift, accessibility, dependency, and theme compatibility remain gates.
#5	FinalChat composer attachments/banner and scroll behavior	CI failing and review changes requested; behavior needs regression proof against the consuming app.
#6	Hooks, Kbd/KbdGroup, Separator	CI failing; path/config baseline and dependency-free claims must be reconciled before integration.
#7	Theme toggle and kitchen-sink pending markers	CI failing and review changes requested; lab theme controls must not redefine Agent UI theme authority.
#8	Sonik Inbox three-pane demo	Open, stacked on #2, mostly local/mock backend behavior; it is a demo, not integrated production capability.

No code from these PRs is part of this completion baseline unless a later commit explicitly merges/adopts it and passes this repository's gates.

9. Ownership

This run owns

- PR 61 CodeRabbit/contract hardening with regression-first fixes;
- session, prompt, stream, telemetry, and host-context proof;
- embedded Workbench reachability and correct server/client/sandbox boundaries;
- theme/component/JSON-render audit;
- bounded preview/staging API checks, verification, PR update, test deployment, and retrospective artifacts.

User or other programs own

- LocateAnything/model serving;
- Hermes post-session memory jobs;
- Little Eve/AgentOS job-agent design;
- MCP implementations beyond the accepted slice;
- secret values and environment assignment;
- Booking PR merge/promotion outside an explicitly safe preview deployment;
- merge/adoption decisions for Sonik Svelte PRs 2–8.

Shared boundaries require a redacted handoff record: contract/version, owner, environment, required scope, expiry, and verification result. This run does not silently absorb external production authority.

10. Acceptance gates

A. Contract and regression gate

- Each still-valid CodeRabbit finding has a failing regression check when executable coverage was missing, followed by the smallest root-cause fix.
- Transport, status, bodylessness, schema, authorization, policy, and derived-surface invariants remain intact.
- The six pressure groups have targeted positive, negative, stale/replay, and boundary cases.

B. User-journey gate

- An authenticated operator creates or resumes a session, reloads/navigates, submits a prompt, observes model/tool completion, and reopens the same history.
- Booking launches embedded Dev Workbench at wide and sidebar widths with reachable layout and context controls.
- Host evidence, server authority, preview, terminal, logs, and tool readiness are distinguishable.
- Controlled-preview selection/capture produces revision-consistent sanitized artifacts readable by Codex.

C. Quality gate

- Targeted tests, full typecheck, lint/static checks, and builds pass from a clean dependency state.
- Changed files pass anti-slop review and are reverified.
- Independent code reviewer returns APPROVE and architect returns CLEAR, or any exception is explicitly recorded as a stop.
- No credential, raw chain-of-thought, unsafe telemetry, or sensitive screenshot content is exposed.

D. Deploy gate

- Branch is pushed and PR 61 reflects final commits and verification.
- Preview/staging deployment is successful; URLs and operator instructions are recorded.
- Bounded API reliability checks stop on unexpected 5xx, auth-boundary violation, or unsafe write behavior.
- Production fuzz/load and unsafe writes are prohibited.
- Production promotion requires explicit external approval and correct scoped authority; it is not implied by a green preview.

11. Rollback and insurance

1. Preserve the pre-run PR head and deployed preview identifier.
2. Keep changes surgical and commit by verified slice so a failing slice can be reverted without discarding unrelated work.
3. Do not mutate production data during reliability checks.
4. On auth, secret, tenant, or policy failure: stop, revoke/expire issued capability, invalidate affected sessions/artifacts, and retain redacted evidence.
5. On session/stream regression: disable the new path or revert its commit while preserving the prior known-good session behavior.
6. On visual-context mismatch: invalidate current context and remove the stable promotion; never retain an unmatched PNG/manifest pair.
7. On deploy failure: restore the last known-good preview/production deployment and report the provider request/deployment identifiers.

12. Explicit exclusions

- No new dependency without explicit approval.
- No oRPC introduction when the installed contract stack does not use it.
- No bespoke polling, SSE, or WebSocket infrastructure; reuse the established realtime-egress/Beacon/RivetKit direction.
- No production fuzzing, load testing, unsafe write testing, or credential injection into a sandbox.
- No claim that exact host pixels, MCP, governed deploy, preview restart, console/network panels, or durable AgentOS orchestration are complete without implementation and fresh proof.
- No merge of Sonik Svelte PRs 2–8 as an incidental part of this run.
- No theme replacement or design-system mixing.

13. Run accounting

This run began at **2026-07-20T20:03:01Z** with a **zero-token accounting baseline for this run**. The previously reported **15,067,785 tokens** belong to a prior run and are historical comparison data only. They must not be added to, presented as, or used to imply work performed by this run. The final retrospective will report this run's actual elapsed time and token use from its own checkpoints.

14. Contract sign-off rule

This baseline is accepted when the Markdown, self-contained HTML, and valid PDF agree on the material terms above and the PDF opens successfully. It authorizes implementation within the stated scope; it does not declare the product complete. Product completion occurs only after every required story and gate has fresh evidence, the PR and deployment are updated, and remaining external gaps are named without inflation.